

ELASTIC ENCLAVE HSM

Elastic Enclave HSM — Technical Deep-Dive

EJBCA PKI + SPIRE zero-trust · attested · autoscaling · FIPS 140-3 L1 · PQC-native

Attested key custody on commodity spot EC2 — validated end-to-end on AWS

Agenda

- 01 FIPS 140-3 levels — L1 vs L3
- 02 The problem — CloudHSM cost & rigidity
- 03 Solution & architecture
- 04 Component view
- 05 Attested key custody
- 06 Architecture A — EJBCA PKI flow
- 07 Architecture B — SPIRE zero-trust flow
- 08 Zero-trust use case — OTel identity
- 09 Deployment topology
- 10 Performance — measured
- 11 Resilience — self-healing
- 12 Roadmap — NLB autoscaling

FIPS 140-3 — Level 1 vs Level 3

FIPS 140-3 Level 1

Where high-volume signing runs

Production-grade validated crypto (FIPS-approved algorithms). No physical tamper hardware required. The enclave adds hardware-isolated, operator-inaccessible memory + cryptographic attestation of the exact image that may hold the key — a strong isolation boundary at L1 economics.

FIPS 140-3 Level 3

The CloudHSM / dedicated-HSM tier

Adds tamper-evident/responsive physical security, identity-based operator authentication, and physical separation of plaintext critical security parameters. This is the CloudHSM / dedicated-HSM tier.

TIERED TRUST An L3 root (KMS/CloudHSM) can anchor the trust chain and sign the intermediate; the high-volume leaf/SVID signing runs at L1 inside the attested enclave. You buy L3 assurance once for the root, and scale L1 signing elastically.

The problem — CloudHSM cost & rigidity

Cost of HA at scale

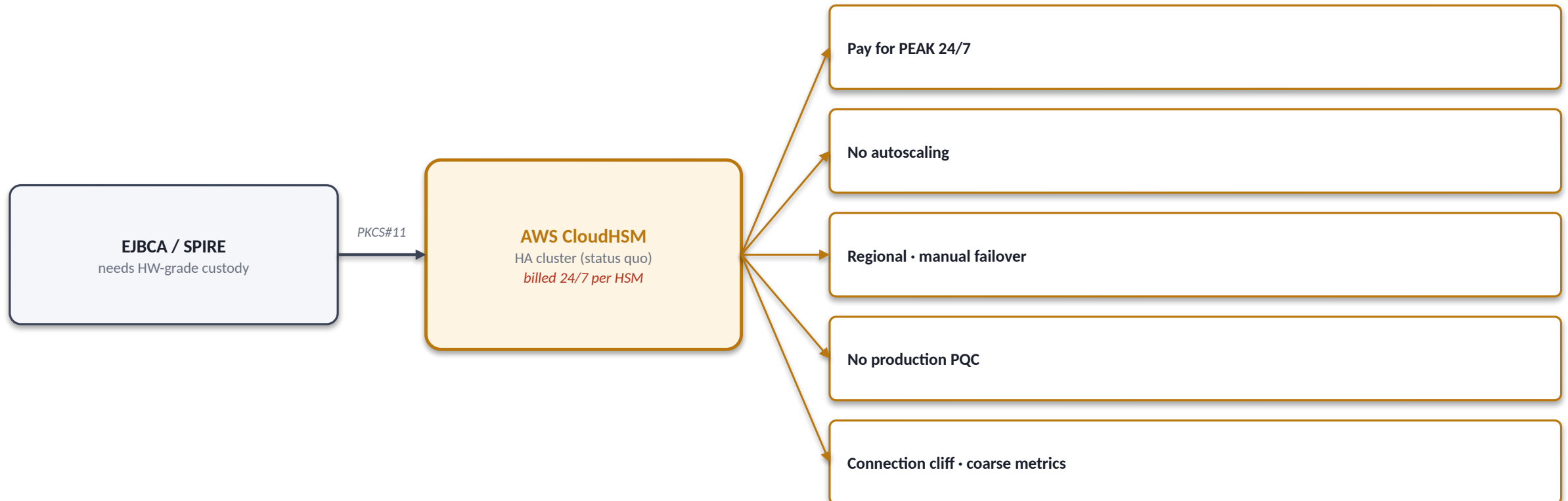
An HA CloudHSM cluster bills 24/7 per HSM for peak capacity — expensive whether you sign 10 or 10,000 TPS.

No autoscaling

Fixed capacity. You provision for peak and pay for it continuously; there is no scale-to-load.

No production post-quantum

No ML-DSA / ML-KEM / hybrid signing in the firmware today.



Solution — four pillars

Elastic — pay for load

No dedicated HSM. Spot EC2 + KMS, autoscale to min when idle. Linear scale-out: add boxes -> +throughput, behind a multi-AZ NLB.

HSM-grade custody (FIPS 140-3 L1)

The CA/ICA key is released only into an attested enclave via KMS and never leaves that boundary. Parent host and operators never see plaintext key.

PQC-native

ML-DSA-65, ML-KEM-768/1024 and hybrid (P-384+ML-DSA) signing — in software, today, not waiting on HSM firmware.

Enterprise resilience

Enclave-aware health reporting; a wedged enclave -> 503 -> NLB -> ASG auto-replaces. Self-heals under chaos, validated on real spot infra.

Architecture

One elastic enclave HSM serves EJBCA PKI and SPIRE zero-trust — key never leaves the enclave

IDENTITY CONSUMERS

EJBCA
PKI cert issuance
PKCS#11 token · libnitrop11.so

SPIRE server
workload identity (SVIDs)
nitro_gateway KeyManager

OTel / Vector agents
aws_iid · app/component SANS
host · service · agent identity

**Internal
NLB**
multi-AZ
cross-zone
TCP health

AUTOSCALING GATEWAY / ENCLAVE FLEET · spot ASG

EC2 box 1 (parent)

gateway-bridge
mTLS :8443 · /healthz

NITRO ENCLAVE

enclave-signerd
ICA (ECDSA P-384)
+ managed SVID keys
+ PQC: ML-DSA / ML-KEM
key never leaves
vsock only · attested

EC2 box 2 (parent)

gateway-bridge
mTLS :8443 · /healthz

NITRO ENCLAVE

enclave-signerd
ICA (ECDSA P-384)
+ managed SVID keys
+ PQC: ML-DSA / ML-KEM
key never leaves
vsock only · attested

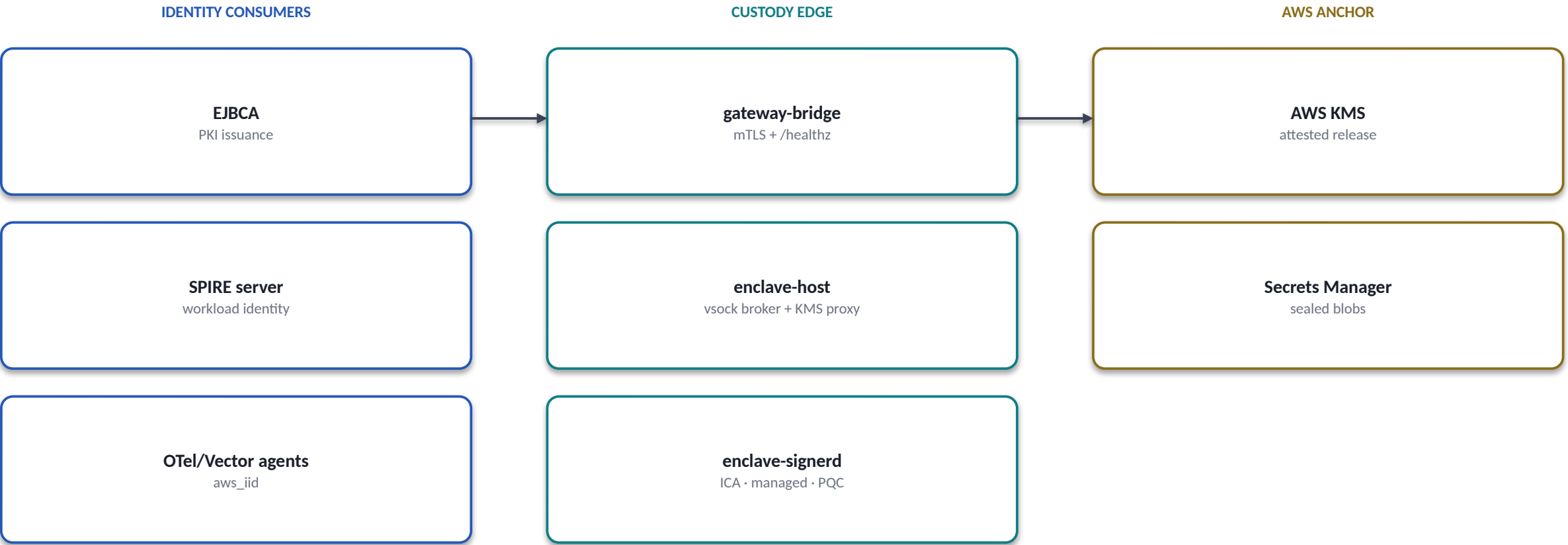
AWS TRUST ANCHOR

AWS KMS
attested release
(FIPS 140-3 L3
root option)

Secrets Mgr
sealed ICA +
managed-key vault
(inert ciphertext)

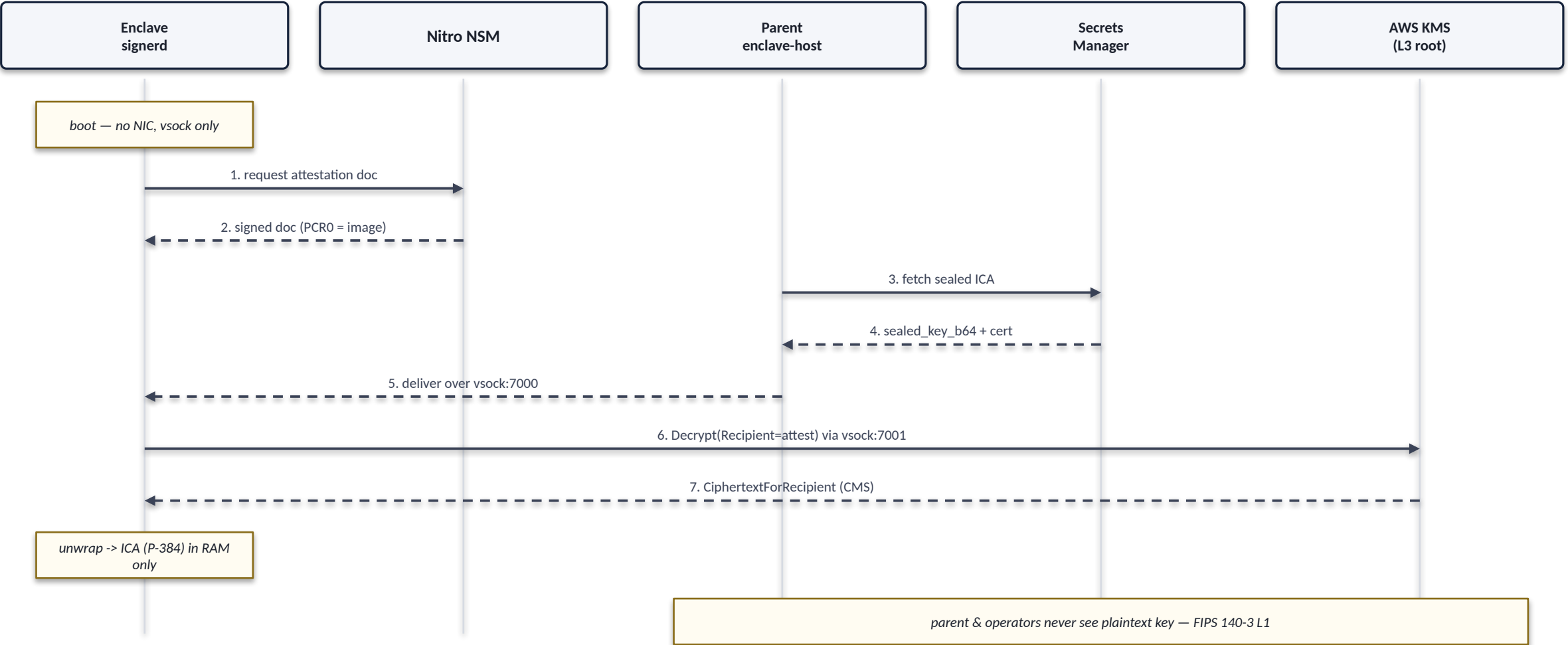
Component view

gateway-bridge → vsock broker → enclave signer — the request path, component by component



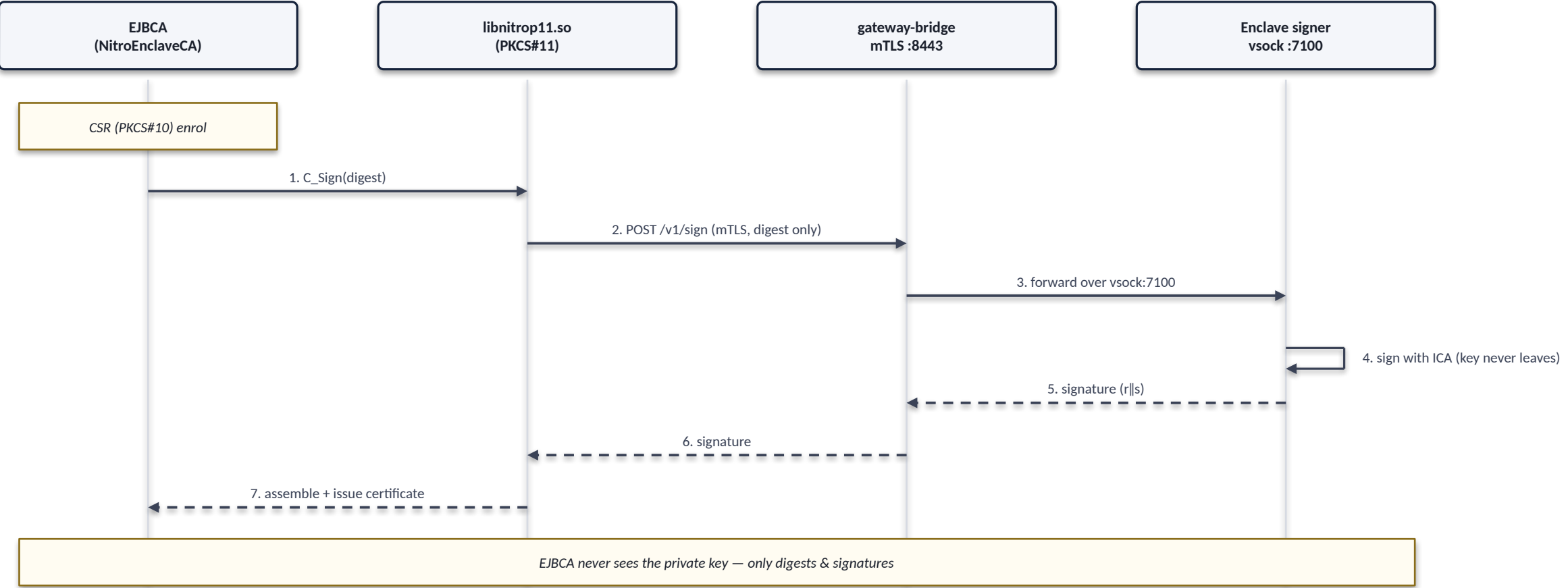
Attested key custody

NSM attestation → KMS Decrypt with Recipient → ciphertext re-wrapped to the enclave key → unwrapped only inside the enclave



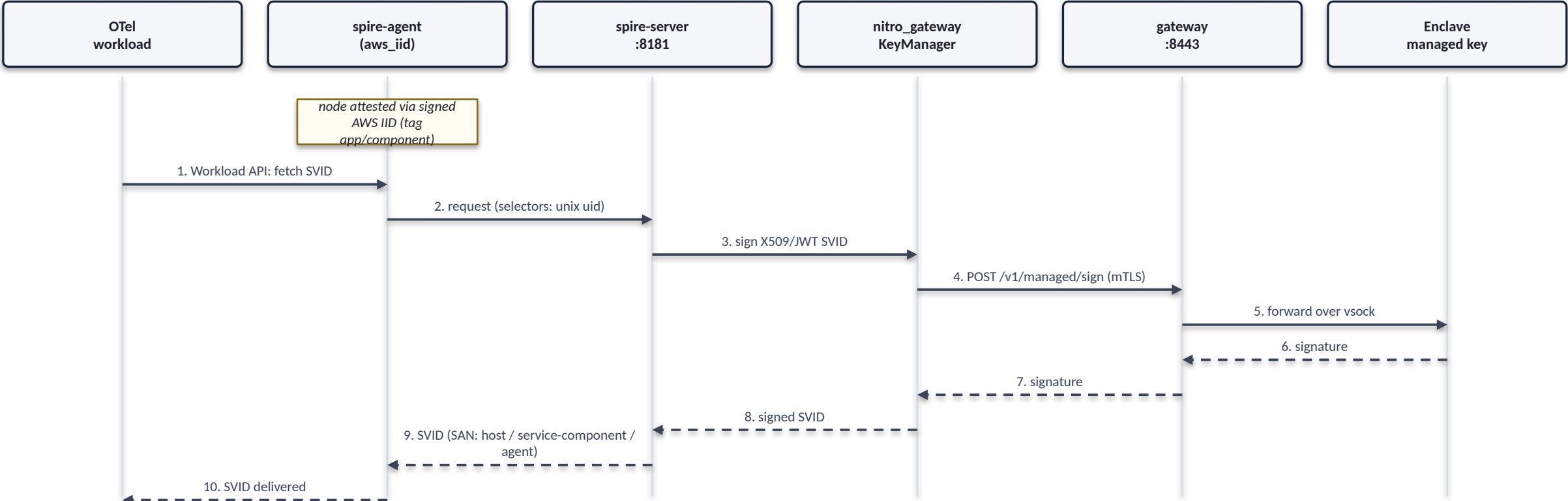
Architecture A — EJBCA PKI issuance

Stock PKCS#11 token (libnitrop11.so): every C_Sign forwards over mTLS to the in-enclave ICA — no EJBCA rebuild



Measured ~895 certs/sec/node (ecdsa-p256, 0 errors); EJBCA-bound, scales with EJBCA nodes.

Architecture B — SPIRE zero-trust



Measured ~236 SVIDs/sec (agent->server->gateway); SPIRE-server-bound, scales with servers.

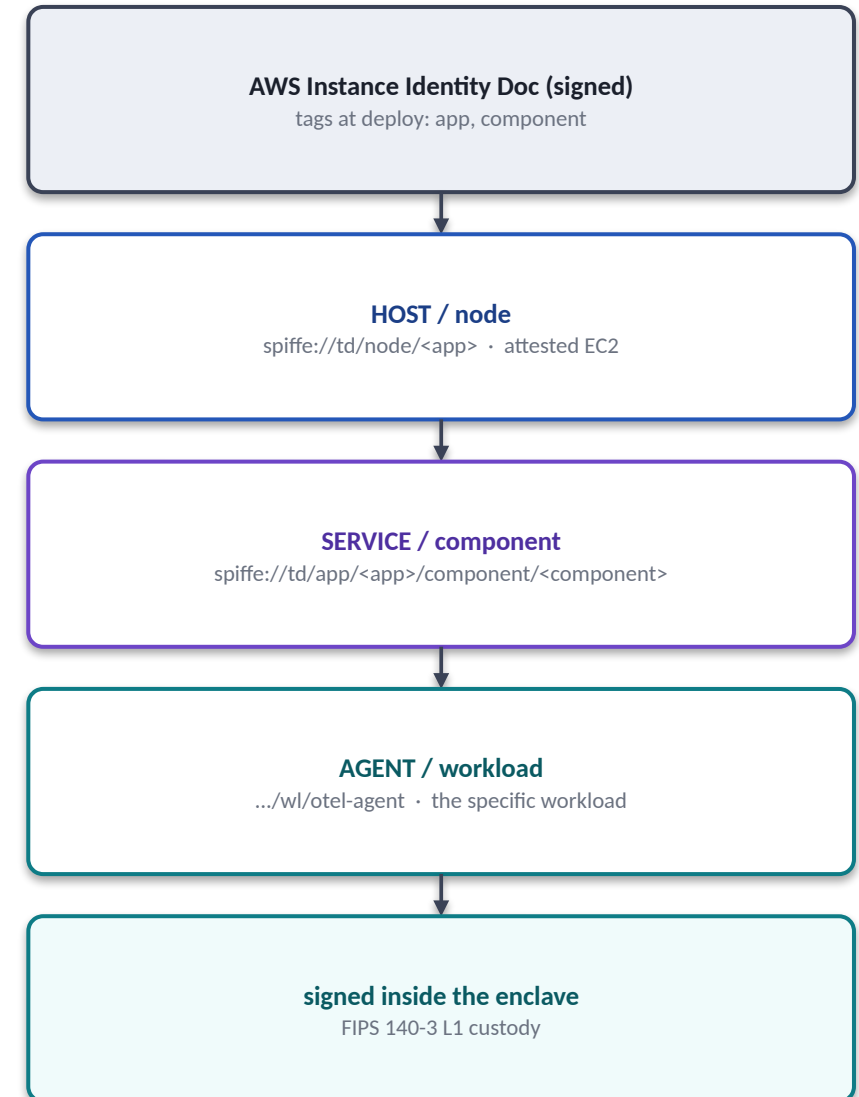
Central trust root: the SPIRE server can be an EJBCA child ICA via UpstreamAuthority — one root anchors both PKI and workload identity.

Zero-trust use case — OTel by app + component

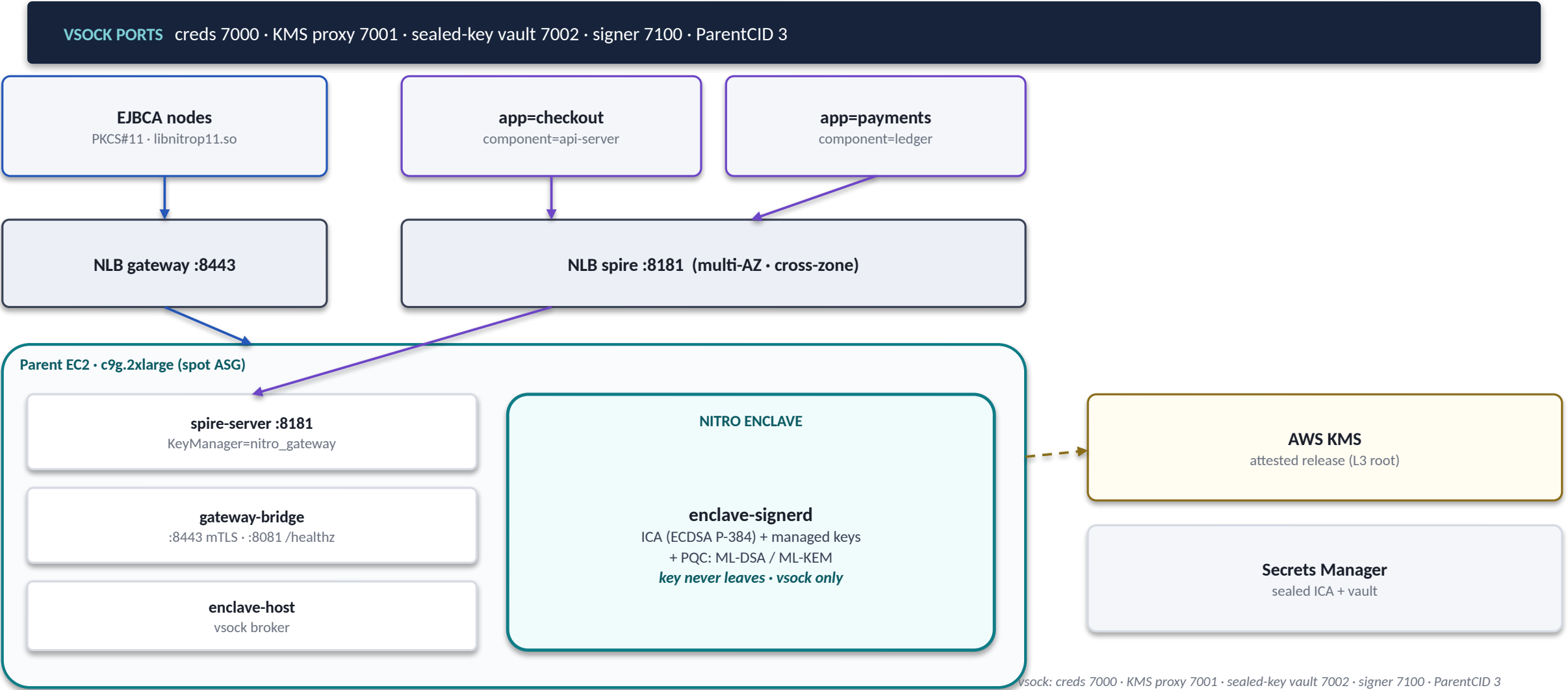
- ▶ **Host / node** `spiffe://td/node/<app>`
the attested EC2 instance (aws_iid, tag:app)
- ▶ **Service / component** `spiffe://td/app/<app>/component/<component>/...`
the application component — set from deploy-time tags, not inferred
- ▶ **Agent / workload** `.../wl/otel-agent`
the specific workload on the node (unix selector)

At deploy time each instance is tagged **app** and **component**.

SPIRE's aws_iid node attestor reads the signed AWS Instance Identity Document, resolves the tags, and mints host / service / agent SANs — each SVID signed inside the enclave.



Deployment topology



Performance — measured, honestly labeled

HSM CEILING

~8.6k/box → 48k fleet

EJBCA ISSUANCE

~895 certs/s/node

SPIRE SVIDS

~236 SVIDs/s

Cipher	signs/sec
ECDSA P-256	4,374
ECDSA P-384	7,530
RSA-2048	2,888
RSA-4096	497

Cipher	signs/sec
ML-DSA-65 (PQC)	6,261
ML-KEM-768	7,912
ML-KEM-1024	8,478
Hybrid P-384+ML-DSA-65	6,207

Takeaway: the signer is never the bottleneck — ~10-36× headroom over both product paths.

Resilience & roadmap

Self-healing today

Enclave-aware **/healthz** probes the vsock signer, not just the parent process.

A wedged enclave → **503** → NLB drops the target → ASG auto-replaces the box.

Validated on real spot infra under HA chaos — traffic reconverges with zero operator action.

Roadmap

Two internal NLBs (SPIRE :8181, gateway :8443) + shared RDS + a Secrets vault.

Both tiers become stateless and scale horizontally, independently — PKI and identity load no longer share a box.

Ref: **NLB-SCALING-PLAN**

VALIDATED

single-box + HA chaos

NEXT

NLB autoscaling ×2 tiers